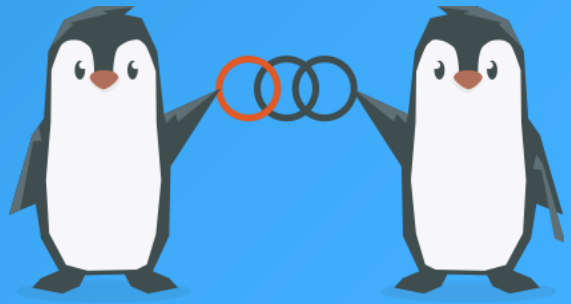
# Open Source Summit Europe 2026
# 速報

OpenChain project Japan Working Group

THE LINUX FOUNDATION

OPENCHAIN



# Open Source Summit Europe 2026

## オープンソースで、より強く、より自律的なヨーロッパの未来へ

7-9 OCTOBER 2026 | PRAGUE, CZECHIA

世界中から多様な人々が集い
オープンソースの可能性を議論する、
ヨーロッパ最大規模のイベント




### イベント概要

Open Source Summit Europeは、欧州および世界中から開発者・企業・政府・コミュニティが集まった、ヨーロッパ最大規模のオープンソースイベントです。AI・セキュリティ・デジタル主権を中心に、技術・政策・社会の視点からオープンソースの未来が議論されました。

### このイベントの重要ポイント

- AI・セキュリティ・デジタル主権が主要テーマとして議論
- 世界中から2,344名が参加する最大規模のオープンソースイベント
- 技術・政策・社会の多角的な視点でオープンソースの未来を検討
- 59のスポンサーが参加し、活発な交流と発信
- 多様な業界・職種・地域からの参加により、オープンソースのエコシステムの広がりと影響力を再確認

### 参加規模

- **2,344名** 現地参加者数
- **987** 参加組織数
- **59社** スポンサー数

### 参加者の地域分布




### 参加者の特徴

**68%** が技術職

### 参加者の多い国

1. USA
2. CZECHIA
3. FRANCE

ほか、世界各国から参加

### 主な職種（上位）

| | |
|---|---|
| エンジニアリング／ソフトウェア開発 | 49.0% |
| アーキテクチャ（ソフトウェア／システム） | 6.2% |
| 経営・エグゼクティブ | 4.0% |
| IT運用／インフラ | 3.1% |
| 営業／マーケティング／メディア | 2.5% |
| DevOps／サイト信頼性エンジニアリング | 2.2% |
| コミュニティ運営 | 1.8% |
| セキュリティ／コンプライアンス | 1.4% |
| 学生／アカデミア | 1.4% |
| プロダクトマネジメント | 1.4% |
| 教育／トレーニング／研究 | 1.4% |
| データサイエンス／AI／機械学習 | 1.4% |
| その他 | 10.3% |

### 主な業界（上位）

| | |
|---|---|
| 情報技術 | 45.7% |
| 通信 | 13.2% |
| 自動車 | 5.6% |
| エネルギー | 4.9% |
| 消費財 | 4.6% |
| 金融 | 3.0% |
| ヘルスケア | 2.4% |
| その他 | 2.3% |

### カンファレンスの規模

- **1,660件** トーク応募数
- **305件** 採択セッション数

### バッジスキャン（現地）

| 平均スキャン数 | 最多スキャン数 | 合計スキャン数 |
|---|---|---|
| 152 | 519 | 6,840 |

### 注目されたトピック（トークのテーマ）

| | |
|---|---|
| 組込みシステム | 51% |
| AI・機械学習・データ分析 | 50% |
| Linux・システム管理／エンジニアリング | 48% |
| DevOps・CI/CD・サイト信頼性 | 39% |
| クラウド・クラウドネイティブ・コンテナ | 38% |
| プライバシー・セキュリティ・コンプライアンス | 37% |
| ネットワーキング・エッジ | 31% |
| リーダーシップ・コミュニティ・ガバナンス | 30% |
| オープンハードウェア | 29% |
| アプリケーション開発・メディア技術 | 27% |
| 安全性が求められるシステム | 26% |
| サステナビリティ | 18% |
| 分散型の信頼 | 15% |

# State of Open Source in Europe Report

## ― オープンソースがつくる、より強く自律的なヨーロッパの未来 ―

オープンに協力し、
より良い社会をつくる

## 概要

欧州の367の組織への調査と、メンテナー・政策立案者・実務者へのインタビューを基にした、年次のオープンソース動向レポート（第5版）。

AIの影響、デジタル主権、セキュリティの3つのテーマから、欧州の強みや課題、今後の方向性を示す。

## 重要なポイント

- AIは大きな機会をもたらす一方で、メンテナーやコミュニティに新たな課題とリスクをもたらしている
- デジタル主権は、欧州の組織にとって重要な戦略テーマ
- セキュリティ対応の負荷が増大し、信頼性の確保が急務
- オープンでよくガバナンスされたプロジェクトが選ばれる
- 欧州は技術的貢献で高い存在感を持つ（世界の30〜40%）

## 主な数値

**欧州からの技術的貢献**




世界の貢献に占める割合

**デジタル主権の重要性**




の欧州の組織が重要と回答

**好まれるガバナンスモデル**

52%

の回答者が財団主導の共同ガバナンスモデルを選好

## 3つの主要テーマと主な議論

### 1 AIの影響　大きな機会と新たな課題



Mirko Boehm

AIはすでにここにあり、多くの組織が既存のオープンソースからより多くの価値を引き出しています。参入の障壁を下げ、馴染みのない技術スタックの理解を助けます。

**主な機会**

- 既存のオープンソースからより多くの価値を得られる
- 参入障壁の低下
- 新しい技術スタックの理解を支援
- 貢献と採用の増加

**主な課題・リスク**

- メンテナーやコミュニティの負荷増大
- セキュリティアドバイザリの急増（従来の数倍）
- AI生成コードと著作権の緊張関係
- AI生成の貢献の扱い方に関するベストプラクティスが未確立

### 2 セキュリティ

金融機関でもオープンソースコミュニティが動き始めている



Gabriele Colombo

金融機関におけるセキュリティ運用の分野で、オープンソースコミュニティが動き始めています。業界全体で知見を共有し、より安全で信頼できる運用の実現を目指しています。

**主な議論のポイント**

- 金融機関でのセキュリティ運用に関するオープンソースコミュニティの取り組みが進んでいる
- 業界横断での知見共有により、より安全で信頼性の高い運用の実現を目指している
- セキュリティ対応の負荷が増大しており、メンテナーへの支援が必要
- 主要な基盤プロジェクト（Linux、Kubernetes、Yoctoなど）がより重要になっている

### 3 デジタル主権

政策と投資が後押しする重要な戦略テーマ



Paula Grzegorzewska

94%の欧州の組織がデジタル主権を重要と考えています。特に欧州では、国家・地域の利益の推進が、他地域より12ポイント高く、政策にもその関心が反映されています。

**主な動向・政策**

- 94%の欧州の組織がデジタル主権を重要と回答（世界全体でも同様の傾向）
- 国家・地域の利益の推進が、他地域より12ポイント高い
- 欧州委員会が「EU Tech Sovereignty Package」を提案（オープンソースに大きく投資する初の主要な法的文書）
- 少なくとも20億ユーロの投資計画（7年間）
- 欧州の公共部門の年間プロプライエタリIT支出は2,640億ユーロ超

## 主な登壇者



Mirko Boehm
Senior Director for Community Development, Linux Foundation Europe



Paula Grzegorzewska
Senior Manager, Strategic Partnerships, Linux Foundation Europe



Thierry Carrez
General Manager, Linux Foundation Europe



Mark Weatherford
AI Cybersecurity Strategist, NVIDIA



Gabriele Colombo
Executive Director, FINOS



Alice Yake
VP GRIDS, Breakthrough Energy

## 今後の方向性

- メンテナーとコミュニティへの支援を強化する
- AI時代の関与・セキュリティ対応のベストプラクティスを発展させる
- デジタル主権を支えるオープンソースへの投資と政策の具体化を進める
- オープンソースを通じて、より強く自律的なヨーロッパの未来を築く

# Open Standards for Trusted Agentic Workloads

## ～ オープンな標準で、信頼できるエージェントの未来を築く ～

オープンな標準が、
エージェントの信頼と
可能性を広げる。




### 概要

開発者体験の変化とエージェントの急速な普及を踏まえ、AIエージェントが安全に協調し、必要なツールや情報に接続できるようにするためのオープンな標準の重要性を紹介。オープンな標準が開発者に柔軟性を与え、AIシステムの構築と拡張を可能にする。

### 重要事項

- 開発者の働き方は過去16～18か月で大きく変化し、エージェントの利用が急増
- セキュリティ・プライバシーや回答の正確性に関する「信頼のギャップ」が存在
- 多くの企業で「ガバナンスのギャップ」も顕在化
- 信頼の解決は技術的な対策だけでなく、オープンな標準という構造的アプローチが必要
- AWSはオープンソースとオープン標準を支援し、業界全体で信頼を築くことにコミット

### スピーカー



**Laura Tacho**
Senior Principal Technologist,
Developer Experience, AWS

オープンソースと開発ツールの分野で15年以上の経験を持ち、AWSで開発者体験とAIネイティブ開発に注力。

### 1 開発者体験の急速な変化

過去16～18か月で、開発者の働き方とソフトウェア開発は大きく変化しています。

オートコンプリート (IDE) → ローカルで動作するエージェント → 非同期で動作するエージェント (リモート実行) → ソフトウェアファクトリー

**開発するソフトウェアも変化**
AIチャットボットを製品に追加する段階から、今では顧客データに関わる重要な本番ワークロードを実行する段階へと進化しています。

### 2 急速に増えるエージェントの利用

エージェントによる活動は、2026年に入って大きく増加しています。

**エージェントが関与するPRの割合** (Jellyfishのデータ)




**エージェントが作成したPR数** (GitHubのデータ)

7.7百万件 (2026年1月) → 71.7百万件 (2026年8月)

約9倍に増加

### 3 信頼とガバナンスのギャップ

エージェントの利用は進む一方で、信頼やガバナンスは同じペースで向上していません。

**信頼のギャップ** (Stack Overflowの調査)

- 81.4% 開発者がデータのセキュリティやプライバシーに不安
- 86.9% 開発者がモデルの回答の正確性に懸念

**ガバナンスのギャップ** (企業内の調査・平均)

- 89% 開発者がAIは仕事の質・イノベーション・ソフトウェアの品質向上に役立つと回答
- 62% 開発者のみが自社がエージェント利用のリスクに適切に対応していると回答

### 4 解決のアプローチ：オープンな標準

信頼の課題を解決するには、技術的な対策だけでなく、オープンな標準という構造的なアプローチが必要です。

**よくある技術的な必策** (短期的な効果)

- モデルの精度向上
- 適切なモデルへのワークロードのルーティング
- エージェントを囲むガバナンスレイヤー

**オープンな標準が必要** (長期的な解決)

- エージェント同士が安全に連携できる
- オーケストレーションや柔軟性のニーズに対応
- 壁ではなく、オープンなシステムを構築できる

### 事例：Cedar ― 移植可能な認可ポリシーで安全にエージェントを実行

Cedar

Cedarは、ポリシー言語であり認可エンジンです。アプリケーションのロジックから切り離してポリシーを定義でき、移植性の高いポリシーレイヤーとして利用できます。エージェントの本番運用において、きめ細かな権限制御を実現します。

**ポリシーの例（エージェント開発の文脈）**

```
permit(
  principal == Agent,
  action == RunTests,
  resource == Sandbox
);
permit(
  principal == Agent,
  action == GitPush,
  resource == Repository,
  when { context.branch != "main" }
);
```

例：メインブランチ以外の場合のみ、git pushを許可する

**PARCで定義**

- P Principal（主体）
- A Action（アクション）
- R Resource（リソース）
- C Context（コンテキスト）

### AWSの取り組み

aws

- Linux Foundationのプラチナメンバーに（10年以上にわたる活動を拡大）
- Agentic AI Foundationの創設メンバー（MCP、A2A、Agent Gateway などのオープン標準）
- Valky、OpenSearch などのプロジェクトにメンテナーとして貢献
- オープンソースコミュニティとコードの健全性を保つため、リソースを提供し、業界全体の発展に貢献

オープンソースのコミュニティは
人と技術の架け橋です。プラハの美しい橋のように、
テクノロジー、コミュニティ、そして私たちを
つなぐ架け橋を築いていきましょう。



**オープンな標準で、信頼できるエージェントの未来を、ともに築いていきましょう。**

Building a more open and trusted tomorrow.

# Open Source at a Crossroads

## 地政学 × デジタル主権の時代に、オープンソースはどこへ向かうのか

よりオープンで、
より強く、より自律的な
デジタル社会へ

## 概要

世界の地政学的な緊張の高まりにより、デジタルインフラへの依存が国家の安全保障や社会の安定に関わるリスクとなっている。デジタル主権の高まりの中で、オープンソースをどのように位置づけ、政府・企業・コミュニティが協力して、より自律的でレジリエントなデジタル社会を実現できるかを議論した。



**Nithya Ruff**
Chair, Linux Foundation Board
Technology Executive,
The Linux Foundation

独立性と自らの未来をコントロールすることは、すべての国に共通するニーズです。オープンソースはその実現に大きく貢献します。



**Johan Linaker**
Senior Researcher at RISE Research Institutes of Sweden and an Adjunct Assistant Professor at Lund University

デジタル主権とは孤立ではなく、戦略的に自律性を高めつつ、可能な限りオープンであり続けることです。

## 重要事項

- デジタルインフラは社会・産業・政府の基盤であり、依存は国家の安全保障やデジタル主権に関わるリスクとなっている。
- デジタル主権は「孤立」ではなく、戦略的に自律性を高めつつ可能な限りオープンであり続けること。
- オープンソースは、政府・企業・コミュニティが協調し、自律性・レジリエンス・持続可能性を高めるための戦略的な柱である。
- 影響力やセキュリティ、持続可能性は自然には得られず、政府もインフラの維持・発展に貢献し、ガバナンスの場に参加することが重要。

## 1 地政学の動向とデジタル主権の高まり

世界で地政学的な緊張が高まり、各地域がデジタル主権を重視している。

**中国**
過去10年で
オープンソースや
オープンウェイトモデルに
大規模に投資し、
**世界をリード。**

**米国**
輸出規制の議論や、
州・連邦レベルでの
規制のパッチワーク化
が進行。

**欧州**
デジタル主権を重視し、
EUの関連施策
(Sovereign Tech Fund、Cloud and AI Development Act、オープンソース戦略など)が進展。

地政学的な緊張の高まりにより、
デジタルインフラへの依存が現実のリスクに変化

## 2 デジタル主権とは何か

デジタル主権の本質は「孤立」ではなく「自律性の確保」。



Johan Linaker

デジタル主権とは、
国や組織が依存するデジタルシステムを
自ら形成し、利用し、維持する能力です。
「自国だけで作る」ことではなく、戦略的に
重要な領域で自律性を高めつつ、可能な限り
オープンであり続けることです。

**よくある誤解**
- ✕ 自己隔離
- ✕ 完全な自給自足
- ✕ “Made in ○○” = 主権

**本質**
- ✓ 戦略的な自律性
- ✓ 可能な限りオープン
- ✓ 社会のレジリエンスと持続可能性の確保

## 3 オープンソースは両立の鍵

デジタル主権とグローバルな協調は、両立することができる。



Nithya Ruff

政府も企業も、どこで協力し、
どこでオープンにし、どこでコントロールを
持つかを決めることができます。
たとえ競合であっても、共通の基盤では
協力することができます。

**政府**
- デジタル公共インフラの共有・協力・再利用
- 政治的に異なる国同士でも協力が可能

**オープンソースで両立可能**

**企業**
- 競合しながらもコア部分で協力
- Linux、Apacheなどの共同投資プロジェクトやAI分野での共同開発
(例：AlphaOmega、Akrites)

## 4 業界の学びと政府の遅れ

企業は1980〜90年代に競争から協調へと移行し、オープンソースの成功モデルを築いてきた。

**1980〜90年代**
各社が独自のUnixフレーバー
(HP、Sunなど)で激しく競争

**Linux・Apacheで**
**共通基盤に協力**

**企業内にOSPOを設置し**
**戦略的にオープンソースを推進**

**現在**
セキュリティやAIなどで
共同投資が進展
(例：AlphaOmega、Akrites)

**なぜ政府はこの学びを長く活かせなかったのか？**
これまでも先駆的な取り組みはあったものの、本格的に進んだのは近年。デジタル主権の必要性が高まってからです。



Johan Linaker

## 5 今後に向けて

より自律的でレジリエントなデジタル社会の実現に向けて。

- 政府もインフラの維持・発展に貢献し、ガバナンスの場に参加する。
- 重要な領域を特定し、そこに投資・注力する。
- 政府・企業・コミュニティが協調し、オープンソースを戦略的に活用する。
- 危機時や最悪の事態にも社会が機能し続ける、レジリエントなデジタルインフラを構築する。

よりオープンで
より強く
より自律的な
社会へ

オープンソースの力で、より自律的でレジリエントな社会を共に築く

# The Future of Open Source Security in the Age of AI

## AI時代におけるオープンソースセキュリティの未来

オープンソースを
より安全で持続可能な未来へ

### 概要

オープンソースは産業とイノベーションを支える不可欠な存在であり、AIの進展により脆弱性の増加や攻撃の高速化など新たな課題が生じています。
本セッションでは,OpenSSFの取り組みやAIの活用により、オープンソースのセキュリティを強化し、メンテナーの負担を軽減する方向性が示されました。

### 重要事項

1. オープンソースの利用は**年率30%以上**で増加
   多くの企業ソフトウェアが依存
2. 脆弱性の開示は2019年比で**4倍**（今年は66,000件の見込み）
   AIにより攻撃者が容易に犯罪を行えるようになり、攻撃も急増
3. 脆弱性の発見から悪用までの時間は**29分**に短縮
   （従来は数日）。Time to exploit は**マイナス**の状況も
4. AIは防御側の強力な味方。ノイズの削減や迅速な修正に活用
   ただし人間のレビューが不可欠

### アクションアイテム（今後の方向性）

- AIを防御側の戦略に取り込み、
  脆弱性対応やパッチ管理の方法を見直す
- OpenSSFやAkritesの取り組み・ツールを活用する
- オープンソースメンテナーの支援と持続可能性の確保
  を引き続き検討する

### 主な登壇者

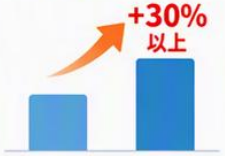



**Jamie Thomas**
Chief Client Innovation Officer
| Enterprise Security, IBM

OpenSSF Governing Boardの創設メンバー（2020年〜）。IBMでエンタープライズセキュリティ（サイバーオペレーション、プロダクトセキュリティを含む）を担当。

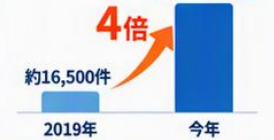
### ① 現状と課題：AIで変わる脅威の規模とスピード

**オープンソースの利用は年率30%以上で増加**




ほぼすべての企業ソフトウェアがオープンソースに依存

**脆弱性の開示は2019年比で4倍**




AIにより攻撃者が容易に犯罪を行えるようになり、サイバー攻撃やマルウェア攻撃も急増

**発見から悪用までの時間は29分に短縮**




従来は数日あったが、現在は「Time to exploit はマイナス」の状況もあり、開示時点ですでに攻撃が行われているケースも発生

### ② AIの活用事例と学び

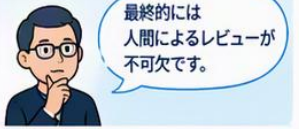
**Curlプロジェクト**

AIが報告する脆弱性の多くはノイズであることが判明。ノイズの削減が重要。




**Linuxカーネル**

AIを使った修正を試験的に実施。ジュニア開発者からは良い評価だったが、経験豊富な開発者のレビューでは回帰（regression）が見つかった。




### ③ メンテナーの課題

オープンソースのメンテナー約60,000人は無償で活動しており、そのうち60,000人が新しい職業への転職を検討したことがある。




### ④ OpenSSFとAkritesの取り組み

**OpenSSF**（2020年設立）

- オープンソースのセキュリティ戦略、ポリシー、ツール開発を推進
- いわば「免疫システム」

連携

**Akrites**（今年設立）

- オープンソースのインシデントレスポンスチーム
- メンテナーや修正作業の支援、対応の優先順位付け

### ⑤ 主なツール・取り組み

| | | |
|---|---|---|
| **Scorecard**<br>プロジェクトの健全性評価 | **コード署名（Sigstore）**<br>ソースコードの真正性を確保 | **SLSA**<br>サプライチェーンの自動化・管理 |
| **OpenBao**<br>シークレット管理 | **GUAC**<br>グラフ分析 | **AI/ML作業グループ**<br>教育・ホワイトペーパー<br>モデル署名（暗号による改ざん防止）など |

AIを味方に、オープンソースのセキュリティをより強固に、そして持続可能なものに

# From Open Source to Agentic Systems: Building the AI Native Era

オープンソースで切り拓く、
AIネイティブの時代へ




## 概要

オープンな標準、協調的なガバナンス、共有のセキュリティ投資の収束が、AIとエージェントコンピューティングのあり方を変えています。組織は自らの学習ループをコントロールし、適切なモデルと実行環境を選び、オープンソースの力でAIの価値をより自由かつ安全に活用できるようになります。

## 重要事項

1. 組織の学習ループは自組織が所有すべきで、単一のAIプロバイダーに縛られるべきではない
2. モデルと実行環境の選択は組織の判断で行う（用途に応じて最適なものを選択）
3. オープンソースの技術スタックにより、異なるモデル・環境への移行とポータビリティを実現できる
4. AIの活用が加速する中で、オープンソース依存の増加に伴うセキュリティリスクに対応し、規制（CRAなど）を遵守することが重要

## 1 組織の学習ループ

AI資本と人の資本の相互作用が、組織の成長エンジンになる

人が文脈と判断を与える

**AI資本**
(AI Capital)
- モデル
- コンピューティング
- トークン

**学習ループ**
（組織の成長エンジン）

**人の資本**
(Human Capital)
- 従業員
- 知識
- 判断力

AIが大規模な洞察を提供
→ 人が知識に変える

この学習を通じて蓄積される組織の知識は、
自組織が所有すべきであり、外部のAIモデルに渡すべきではない。

## 2 適切なモデルを選択する

問題の理解度に応じて、最適なモデルに移行できる柔軟性が重要

**プロプライエタリな最先端モデル**
- 最初に試すのに最適
- まだ十分に理解していない問題に有効

**小規模言語モデル（SLM）**
- ドメイン特化モデル
- オープンウェイトモデル
- 問題を理解するにつれ
- より適したモデルへ移行

特定のモデルに知識を閉じ込められるべきではなく、
用途に応じて自由にモデルを切り替えられることが重要。

## 3 実行環境を選ぶ

同じ学習ループを、最適な環境で実行できるべき

**主権が確保された環境（Sovereign Environment）**
- 自国の管轄・ルールのもとで運用

**オンプレミス（On-premises）**
- 自社環境で運用

**パブリッククラウド（Public Cloud）**
- スケールとコストの利点

どこで実行するかの選択は、
組織自身が決めるべき。

## 4 オープンソースのAIスタック

オープンソースの技術によって、移植性と柔軟性のあるAI基盤を構築

**モデル（Models）**
- Phi などのオープンソース・オープンウェイトモデル（小規模言語モデルで多様なAIジョブを実行）

**アプリケーション（Application）**
- Radius（CNCFプロジェクト）
- アプリケーションを一度定義し、実行環境を選択可能

**オーケストレーション・AI基盤（Orchestration & AI Infra）**
- Kubernetes への貢献
- AI Runway（異なるモデルの切り替えを容易に）

**OS・基盤（OS & Foundation）**
- Azure Linux
- Flatcar などのLinux OSに貢献

アプリケーションから基盤まで、Microsoftは各レイヤーで貢献

## 5 AIの加速とセキュリティの重要性

AIにより開発のスピードと規模が飛躍的に向上する一方、
オープンソース依存の増加により、セキュリティリスクの表面積も拡大。

AIで開発がこれまで以上に高速・大規模に → 生成されるコードはより多くのオープンソース依存を含む → その結果、セキュリティリスクの表面積が拡大

## 6 オープンソース依存の現状

Microsoftでは、**106,000件**のオープンソース依存関係を保有（直接・推移的・依存関係の依存関係を含む）。
CISAや欧州のサイバーセキュリティ機関と共有し、
この規模での運用が意味することを共同で研究。

**106,000 件**
のオープンソース依存関係

これは特別なことではなく、今の世界における現実であり、すべての組織に共通する状況です。

## 7 CRA（サイバーレジリエンス法）のポイント

規制当局は、オープンソース依存の安全性確保を重視。
最近発効したCRAは、次の3つのシンプルな要件を示しています。

1. **オープンソース依存関係をセキュアにする**
   オープンソースはもはや製品の一部であるという認識を持つ
2. **脆弱性を速やかに報告する**
   悪用可能な脆弱性はすぐに報告する
3. **長期的なサポートを提供する**
   製品を出荷した後も、継続的にサポートし、セキュリティパッチを提供する

## 8 今後に向けて

CRAの要件をすべての企業が個別に対応するのは困難です。これまで他の領域で活用してきたオープンソースの実践と同様に、共通の取り組みで対応していく必要があります。

その取り組みの一つとして、
Orbit Launchpad Working Group
を立ち上げました。

# Keynote: Linus Torvalds と Dirk Hohndel の対談

オープンソースの過去・現在・未来について
2人が語り合ったセッション

## 概要

Linux と Git の生みの親 Linus Torvalds 氏と、
Ericsson のソフトウェアテクノロジー責任者 Dirk Hohndel 氏による対談。
Linux の始まりからコミュニティとの関わり方、ソース管理の変遷まで、
オープンソースの歩みと学びについて率直な会話が行われた。

## 重要事項

- Linus 氏は当初、受け取ったパッチをすぐには適用せず、自分で書き直していた。
- 小規模プロジェクトではパッチと tarball による運用がうまく機能した。
- プロジェクトが成長する中で CVS を試したが課題が多く、分散型の仕組みを重視。
- BitKeeper は分散型で優れた体験をもたらしたが、受け止め方は賛否があった。
- コミュニティと協力する姿勢は時間をかけて身につくものであり、重要な学びだった。

## 1 出会いと、それぞれの歩み



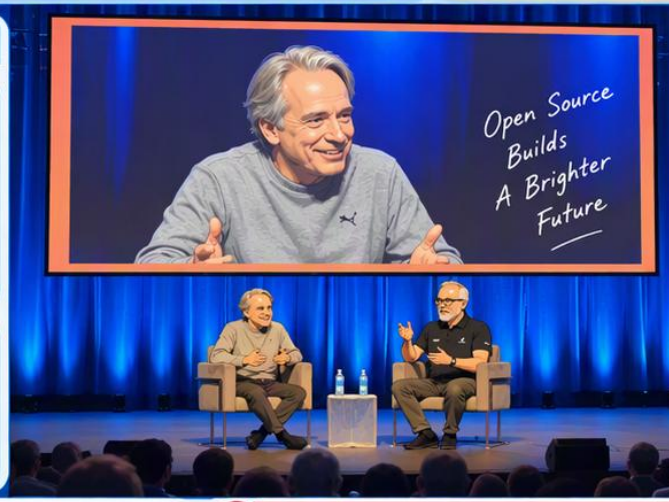
**Dirk Hohndel 氏**

おはようございます。
私は Dirk Hohndel です。
最近 Ericsson に加わり、オープンソースの開発者チームと一緒に仕事をしています。
私は長い間オープンソースに関わってきて、35年と言われることもありますが、
自分でも信じがたいですね。
でも、ここに皆さんがいて、私たちがいるということがすべてです。



**Linus Torvalds 氏**
Linux と Git の生みの親

私は人前で話すのがとても苦手で、
今でも少し緊張します。
この形式（対談）だと準備をしなくてよいのでリラックスできます。
Dirk がその場で質問を考えてくれるので、
私は何も準備せずに来て、できるだけその場を楽しもうにしています。




## 2 初期のパッチ運用

プロジェクトの初期、Linus 氏は
送られてきたパッチをすぐには適用せず、
自分で書き直していた。

これは私だけに特別なことではないと
思いますが、最初は「これは自分のプロジェクトで、自分がコードを知っている」という意識が強かったのです。

送られてきたパッチ → 内容を読み意図を理解 → 自分で書き直して取り込んでいた

## 3 パッチと tarball による運用

初期の Linux ではソース管理システムを使わず、
パッチと tarball で開発を進めた。

毎日パッチを作り、少なくとも週に1回はリリースしていました。
小さなプロジェクトでは、これが驚くほどうまく機能しました。

日々のパッチ作成 → 週次で tarball と diff をリリース

## 4 CVS との出会いと課題

プロジェクトが成長する中で、一部のサブシステム（特にネットワーク）は
CVS に移行したが、Linus 氏は CVS を積極的に使わなかった。

私は仕事で CVS を使うようになり、
それが実際の「使わない理由」になりました。
中央リポジトリの運用やコミット権限の管理など、
多くの手間がかかり、複雑でした。
ブランチはまるで「ブラックマジック」のような体験でした。

CVS

- 中央リポジトリの運用が必要
- コミット権限の管理が大変
- リリースのタグ付けに時間がかかる
- ブランチが複雑

## 5 BitKeeper との出会い

Larry McVoy 氏が開発した BitKeeper は、Linus 氏にとって
分散型で優れたソース管理の体験をもたらした。

BitKeeper は、ソース管理がこうあるべきだと思える最初のシステムでした。
データを中央に閉じ込めるのではなく、
分散型でうまく機能する仕組みでした。
私はこの体験をとても気に入りました。
ただ、受け止め方は人によって異なり、賛否があったと思います。




分散型での開発

## 6 コミュニティと共に学び続ける

他の人と協力し、コミュニティの一員として開発を進めることは、
時間をかけて学んできた重要なことである。

他の人と一緒に開発する方法を学ぶには時間がかかります。
外部からの助けを受け入れ、コミュニティの一員として
感じてもらうことが大切です。
私は怠け者なので、「簡単に適用できるパッチがあるのに、
なぜ自分で余計な作業をするのか」と気づいたとき、
少しずつ変わっていきました。

オープンソースは
人と人の協力で成り立つ

オープンソースは、これからもより良い未来をつくっていく

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

# OpenSSF × 日本企業メンバーの個別ミーティング

— オープンソースの力で、より安全で信頼できるAIの社会実装へ —

共に考え、共に創る
より安全なAIの来来へ

2026年10月8日
個別会議開催

## 3行要約

1. OpenSSFの最新動向（AI・CRA・Open Source Steward・メンバーシップ・政策活動）を共有し、日本企業からの質問・意見をもとに議論した。
2. AIの安全な開発・運用やCRAなどの規制動向、OpenChainとの連携について相互理解を深め、今後の協業の可能性を確認した。
3. 日本における普及の課題（ユーザー企業での人材・ベンダー依存など）を共有し、コミュニティ・政策対話・地域イベントを通じた連携の方向性を整理した。

## 決定事項

- AI関連プロジェクトの継続推進と、ドキュメント・トレーニングの整備を進める。
- CRAやAI Actなど規制動向を踏まえ、ユーザー企業・ベンダーとの連携を強化する。
- 日本との政策対話（経産省・総務省等）を継続し、アジアでの政策イベント開催の可能性を検討する（2027年のアジア開催を視野）。
- OpenChainなど関連プロジェクトとの連携を深化する。

## アクションアイテム

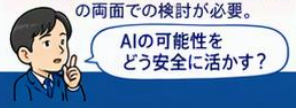
- [ ] AIを使った脆弱性検出・修正のトレーニングコース（年内〜2か月以内）の公開準備を進める。
- [ ] 自動車・組込み・物理AI向けのリファレンスアーキテクチャやガイダンスの検討を開始する。
- [ ] 日本企業への普及に向けた課題（ユーザー企業でのセキュリティ人材・ベンダー依存など）について、今後の対応を議論する。
- [ ] 日本での政策イベント（2027年アジア開催の可能性）に向けた関係者との調整を進める。

## 背景と目的

AIの急速な普及により、新たなリスクと機会が生まれている。また、CRAなどの規制強化も進み、オープンソースコミュニティで安全・信頼できるAIの開発・運用を推進するため、日本企業との意見交換を行い、課題の共有と今後の協業の可能性を探ることを目的として本会議を開催した。

### なぜ今、AIのセキュリティ？

- AIで脆弱性の発見は容易になったが、検出結果のトリアージ・重複排除・真の脆弱性特定・パッチ作成にはコストがかかる。
- AIのサプライチェーンは複雑（モデル・データ・推論・エージェントなど）で、新たなリスクがある。
- 自動車・組込みなど物理AIへの適用も進み、セキュリティと安全性の両面での検討が必要。




## OpenSSFの主な取り組み

### Safe Agentic Framework

- MCPと安全なMCPデプロイに焦点
- MITREフレームワークのリスク・脅威をMCPにマッピング
- 活発なワーキンググループ

安全なエージェントの開発・運用を支援

### スケールアレイ（リスク評価ツール）

- エージェント型ワークロードのリスク評価に利用可能
- プロジェクトに導入し、どのようなリスクが生じるかを把握

AIワークロードのリスクを可視化

### AIワークフローのエンドツーエンド・プロビナンス

- AIパイプライン全体のプロビナンスに焦点
- モデル・データセット・推論などすべての要素を追跡
- SLSAの上に構築（AI/ML特有の要素も考慮）

AIサプライチェーンの透明性を確保

### OSSCRS（Cyber Reasoning System）

- AIによる脆弱性のトリアージを支援
- 重複排除・真の脆弱性特定
- 最終的にパッチの提供まで
- Georgia Tech・MITが主導
- U.S. DARPA（AIxCC）の成果を継承・製品化

検出からパッチまでAIで支援

### トレーニング・教育

- Secure Development with AI
- 「AIを使った脆弱性検出・修正」のコースを年内〜2か月以内に公開予定

AIを安全に活用するためのスキルを提供

### Open Source Steward

- CRAの要請として、Open Sourceコミュニティに求められる対応
- 日本コミュニティの疑問をOpenSSFに共有し、コミュニティ全体で議論

オープンな議論を通じて健全なエコシステムづくりを推進

### 政策・規制対応（CRA / AI Act）

- CRAとAI Actの役割分担（システム：CRA、AI部分：AI Act）、
- 欧州委員会・ENISA・各国のCERTとの対話
- 年2回の政策サミット（米国・欧州）
- 2027年のアジア開催も視野に検討

グローバルな政策連携の強化

## 議論のハイライト（主な論点と発言者）

### プロビナンスとモデル署名



AIのプロビナンスはSLSAをベースに、モデル・データセットなどAI特有の要素も考慮する必要がある。

Cybertrust Ikeda-san

### 自動車・組込み・物理AIへの適用



自動車・組込み分野でも既存のセキュリティの考え方が適用できる。データの出所なども含め具体的な検討を進めていきたい。

Renesas Ito-san

### 規制との関係（CRAとAI Act）



欧州ではCRAとAI Actで役割が分かれており、両方がセキュリティをどのように連携させるかが重要。

OpenSSF Madalin

### 日本での普及の課題



日本企業ではセキュリティ人材が不足し、ベンダー依存が大きい。OpenSSFをどのように日本企業に広めるかが課題。

Toyota Endo-san

### Open Source Steward



日本コミュニティの疑問をOpenSSFに共有し、コミュニティ全体で議論したことを高く評価する。

OpenSSF CRob

## 今後の方向性

- 特定領域への適用検討（自動車・組込み・物理AI）
- 規制との関係の整理と連携のあり方検討
- 日本での普及に向けた課題解決（人材・ベンダー依存など）
- 政策イベント（2027年アジア開催）の検討
- コミュニティとの継続的な連携
- フィードバック・協業提案の促進
















発表を行い、自コミュニティの意見を発信・共有し仲間を増やす
Hallway Trackで様々なコミュニティの方々との意見交換を行う
こういった活動がリアル参加の重要なポイント

https://www.flickr.com/photos/linuxfoundation/albums/72177720335097150/with/55587510686

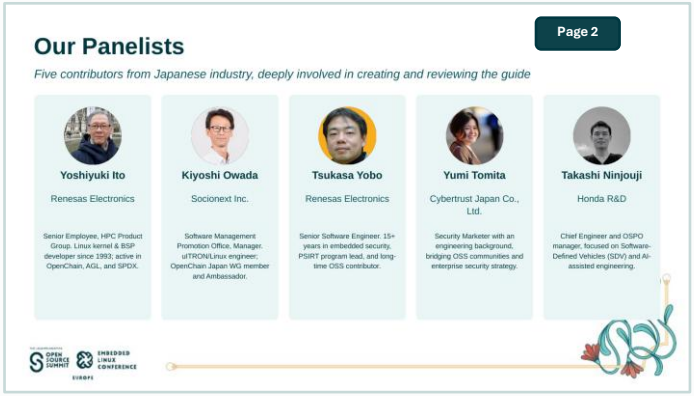
# OpenChain SBOM Document Quality Guide

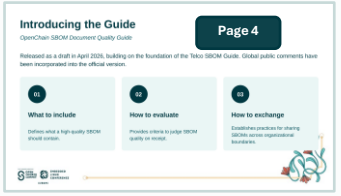
## 発表・パネルディスカッション報告

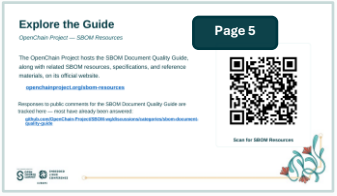
**核心メッセージ**

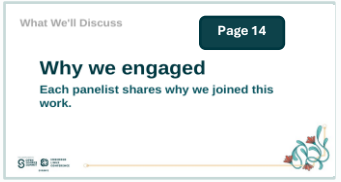
**「SBOMを持っていること」ではなく、受領者が実際に利用できる品質を提供することが重要。**
**その共通基準として OpenChain SBOM Document Quality Guide を整備。**

| | | |
|---|---|---|
| 1 | **議論への参加価値** | ガイド策定への参加は、SBOMを深く理解する実践機会。日本語で議論できる環境も、理解と合意形成を後押しした。 |
| 2 | **実務で見えた品質課題** | 生成タイミングの違いで同一製品でもSBOMが変わる。サプライヤーと利用者が参照する情報も一致しないため、供給側・受領側が同じ情報を共有できる状態が理想。 |
| 3 | **業界横断の適用性** | 自動車・組込みに限定せず、多産業に共通する品質基準を志向。コンポーネント名・識別子・関係情報の不一致など、広範なサプライチェーン課題を対象とする。 |
| 4 | **セキュリティへの展開** | SBOMはライセンス管理から脆弱性管理基盤へ役割を拡大。正確なコンポーネント識別と SPDX／CycloneDX の活用が、脆弱性情報との照合精度を左右する。 |
| 5 | **今後の方向性と会場質疑** | 機械判定可能な品質確認ルールとAI支援に期待。ただし最終承認・判断は人が担う。会場からは①CISA 2026とBSI等の選択、②生成タイミング、③ツールへの原則組込みについて質問があった。 |






登壇者、ガイド概要・参照先、議論参加の背景を原資料から引用

# ELCE 2026：Functional Safetyを巡る議論動向

**Zephyrへの具体実装と、SPDX 3.1 Functional Safety Profileによる安全情報の実運用が前進**

## 1 議論動向：概念から実装・運用へ

### ZephyrでのFuSa議論が深化

認証の必要性やOSSへの誤解に加え、Safety WGとコミュニティ参加まで具体化。

### 安全機構の実装が具体化

IEC 60730 Class B診断をZephyr上で共通化し、再利用可能なAPI・参照実装を志向。

### Safety Caseのデータ化

要求・検証・証拠・前提条件を知識グラフ化し、変更時に再評価する方向へ。

### Safety BOMの実運用へ

供給者の保証と利用者が満たす前提条件を「契約」として交換・検証。

## 2 OSSEU 2026：関連セッション

- **Demystifying Functional Safety in Zephyr RTOS**
  ZephyrにFuSaが必要な理由、開発者の懸念、Safety WGの役割
- **Bringing IEC 60730 Class B Functional Safety To Zephyr**
  自己診断・監視・安全状態処理をオープンなZephyr基盤へ
- **A Safety BOM Is a Contract**
  SPDX 3.1 Profile、SEGkit、証拠の陳腐化検出、契約としてのBOM
- **Safety Critical Software BoF**
  安全クリティカルソフトウェアに関するオープンディスカッション
- **Taming the Safety Dragon With U-Boot and Linux**
  U-Boot／Linuxを含むOSSスタックでの安全対応
- **Feasibility of an Open-Source Linux Platform for Autonomous Train Operation**
  鉄道の混合クリティカリティと継続進化するOSSの認証

## 3 注目例：Safety BOMセッション



### A Safety BOM Is a Contract

1. Zephyrの要求・設計・コード・テスト・証拠を追跡
2. SPDX 3.1で安全成果物を知識グラフとして表現
3. SEGkitで判定再計算と古くなった証拠を検出
4. AssumptionsとGuaranteesを「契約」として形式化
5. Safety Caseから交換可能なSafety BOMを生成

**核心：安全情報を更新・再検証可能なデータへ**

**総括：OSSのFuSa対応は「可能性の議論」から、標準化されたデータモデル、共通実装、継続的な証拠管理へ移行。**